【發明名稱】一種具裝置身分證明之安全預啟動測試機電腦之方法

【發明的想法】

在伺服器與電腦設備之產線測試環境中，測試機電腦須先於Linux作業系統環境下，經由網路取得預啟動程式及診斷核心，才能進行後續之硬體自動化檢測。現有預啟動技術多採用不具身分驗證與傳輸加密之TFTP，且DHCP以廣播方式運作，使任何接上產線網路之裝置皆可能冒充測試機電腦以取得診斷核心，或由偽造之伺服器對測試機電腦派送遭竄改之核心。

本發明之想法係在預啟動前，先使測試機電腦以硬體安全元件向驗證伺服器證明其身分與開機狀態，通過後才核發存取令牌，再以加密傳輸及數位簽章確保預啟動程式之來源與完整性，使預啟動流程符合零信任（Zero Trust）資安架構，同時保留原有動態指派路徑與負載分流之優點。

本想法延伸自期中報告所研讀之TW202418079A專利案，並針對期中報告心得中所指出之TFTP資安風險提出改良。

【最接近的先前技術】

專利公開案 TW202418079A（英業達股份有限公司，發明名稱：一種於Linux作業系統下預啟動測試機電腦之方法）。其係由動態主機設定伺服器將預啟動程式伺服器之網路位置，及該伺服器於Linux作業系統下之根目錄儲存路徑，動態指派予測試機電腦，測試機電腦再依該網路位置及儲存路徑以TFTP取得預啟動程式，並可由負載均衡處理器於複數預啟動程式伺服器間進行負載分配。

【先前技術的缺失】

（1）缺乏裝置身分驗證：先前技術僅依測試機電腦經DHCP取得位置後即可取得預啟動程式，伺服器端無從判斷請求者是否為合法之測試機電腦，未授權裝置可冒充測試機電腦擷取診斷核心。

（2）缺乏傳輸加密與完整性驗證：TFTP以明文傳輸且無驗證機制，測試機電腦於執行前亦未驗證預啟動程式之來源與完整性，易遭竊聽、中間人攻擊或被置換為惡意核心。

（3）缺乏開機狀態證明：伺服器無法確認測試機電腦之韌體與開機載入程式是否遭竄改，遭入侵或竄改之機器仍可取得並執行診斷

核心。

【本發明技術手段】

本發明於先前技術「DHCP 動態指派路徑」之流程中，增設一驗證伺服器，並將預啟動流程改為「先證明、後取得、再驗證」三個階段：

（一）先證明：測試機電腦以其安全元件（如可信賴平台模組TPM），針對驗證伺服器所提供之挑戰值產生證明資料；驗證伺服器將該證明資料與預存之基準度量值比對，相符時核發有效期限且綁定該測試機電腦之存取令牌。

（二）後取得：測試機電腦攜帶存取令牌，依 DHCP 所取得之網路位置及儲存路徑，以加密傳輸協定（如 HTTPS）向預啟動程式伺服器請求預啟動程式及其數位簽章。

（三）再驗證：測試機電腦以預置之驗證金鑰驗證數位簽章，通過後才執行預啟動程式。

存取令牌採自包含、可獨立驗證之設計，使複數預啟動程式伺服器可各自驗證令牌，而不必逐一維護存取名單，因此可與負載均衡處理器並用。

【解決問題】

（1）使未通過證明之裝置，或開機狀態遭竄改之測試機電腦，無法取得預啟動程式及診斷核心。

（2）使預啟動程式於傳輸過程中遭竊聽或置換時，測試機電腦能偵測並拒絕執行。

（3）使存取控制可分散於複數預啟動程式伺服器各自驗證，不致於高併發預啟動時形成新的集中式瓶頸。

【發明目的】

提供一種具裝置身分證明之安全預啟動測試機電腦之方法，使測試機電腦於動態取得預啟動程式前，先以硬體安全元件證明其身分與開機狀態，並以加密傳輸及數位簽章確保預啟動程式之來源與完整性，使產線預啟動流程符合零信任資安架構，且不損及原有動態指派與負載分流所帶來之高擴充性與高效率。

【請求項 1(獨立項)】

一種具裝置身分證明之安全預啟動測試機電腦之方法，適用於一預啟動系統，該預啟動系統包含至少一測試機電腦、一動態主機設定伺服器、至少一預啟動程式伺服器及一驗證伺服器，其中該測試機電腦具有一安全元件及一預置之驗證金鑰，該方法包含以下步驟：

(a)該測試機電腦透過網路連結該動態主機設定伺服器，以取得該預啟動程式伺服器之網路位置、該驗證伺服器之網路位置，及該預啟動程式伺服器於 Linux 作業系統下之儲存路徑；

(b)該測試機電腦自該驗證伺服器取得一挑戰值，並以該安全元件依據該挑戰值產生一證明資料，傳送至該驗證伺服器；

(c)該驗證伺服器將該證明資料與預存之基準度量值比對，於比對相符時，產生一具有效期限且綁定該測試機電腦之存取令牌，並傳送至該測試機電腦；

(d)該測試機電腦依據該預啟動程式伺服器之網路位置及該儲存路徑，攜帶該存取令牌，以加密傳輸協定向該預啟動程式伺服器請求並接收一預啟動程式及其對應之數位簽章；以及

(e)該測試機電腦以該驗證金鑰驗證該數位簽章，於驗證通過時執行該預啟動程式。

【請求項 2(附屬項)】

如請求項 1 所述之方法，其中該儲存路徑為該預啟動程式伺服器於 Linux 作業系統下之根目錄，該預啟動系統更包含一負載均衡處理器及至少二個該預啟動程式伺服器，且於步驟(d)中，該負載均衡處理器於該些預啟動程式伺服器之間分配該測試機電腦之請求，各該預啟動程式伺服器分別以共用之令牌驗證金鑰驗證該存取令牌。

【請求項 3(附屬項)】

如請求項 1 所述之方法，其中該安全元件為可信賴平台模組，該證明資料包含該可信賴平台模組對其平台組態暫存器之值與該挑戰值所產生之簽署引證，該基準度量值為對應該測試機電腦之機型之韌體及開機載入程式之雜湊值；且該存取令牌為一次性令牌，於使用一次或逾期後即失效。

【發明所屬之技術領域】

本發明係關於一種電腦預啟動技術，尤指一種於 Linux 作業系統環境下，具有裝置身分證明及數位簽章驗證之安全預啟動測試機電腦之方法。

【先前技術】

在伺服器及電腦設備之製造測試環境中，測試機電腦於進行硬體診斷前，須先經由網路載入預啟動程式及 Linux 診斷核心。習知技術（如 TW202418079A）係以 DHCP 伺服器動態指派預啟動程式伺服器之網路位置與根目錄儲存路徑，測試機電腦再以 TFTP 取得預啟動程式，並以負載均衡處理器（如 Nginx）於複數預啟動程式伺服器間分流，以解決高併發預啟動時之網路瓶頸。

然而，TFTP 不具備身分驗證與加密機制，DHCP 亦以廣播方式運作，於推動零信任架構之智慧工廠中，存在偽冒裝置竊取診斷核心，或惡意伺服器派送遭竄改核心之風險。另有 UEFI Secure Boot、TPM 遠端證明（Remote Attestation）等技術用以建立開機信任鏈，惟多用於個別終端或雲端環境，本發明係將其整合於上述動態指派與負載分流之產線預啟動測試流程。

【發明內容】

本發明之主要目的在於提供一種具裝置身分證明之安全預啟動測試機電腦之方法，適用於包含至少一測試機電腦、一動態主機設定伺服器、至少一預啟動程式伺服器及一驗證伺服器之預啟動系統。該方法包含：測試機電腦經動態主機設定伺服器取得各伺服器之網路位置及儲存路徑；測試機電腦以安全元件依驗證伺服器所提供之挑戰值產生證明資料；驗證伺服器比對證明資料與基準度量值，相符時核發綁定該測試機電腦之存取令牌；測試機電腦攜帶存取令牌以加密傳輸協定取得預啟動程式及數位簽章；以及測試機電腦以預置之驗證金鑰驗證數位簽章，通過後執行預啟動程式。

本發明可達成之功效如下：(1) 僅通過證明之測試機電腦可取得預啟動程式，可防止偽冒裝置竊取診斷核心；(2) 以加密傳輸及數位簽章，可防止預啟動程式遭竊聽或置換；(3) 令牌具有效期限、綁定特定機器並可設為一次性使用，可防止重放攻擊；(4) 令牌可由各預啟動程式伺服器獨立驗證，不增加集中式存取控制之瓶頸，可與負載

均衡並用。

【實施方式】

請參閱圖 1，為本發明預啟動系統之系統架構示意圖。該預啟動系統包含測試機電腦 11、區域網路 12、動態主機設定伺服器 13（以下簡稱 DHCP 伺服器 13)、負載均衡處理器 14、複數預啟動程式伺服器 15 及驗證伺服器 16，並經由區域網路 12 彼此連接。

測試機電腦 11 包含預啟動韌體 112、安全元件 111 及驗證金鑰 113。安全元件 111 於本實施例為符合 TPM 2.0 規範之可信賴平台模組，用以於開機過程中量測並記錄韌體及開機載入程式之度量值於其平台組態暫存器，且可使用內部之簽署金鑰產生簽署引證。驗證金鑰 113 預置於預啟動韌體 112 中，包含用以驗證預啟動程式數位簽章之公鑰，以及驗證伺服器 16 之根憑證。

預啟動程式伺服器 15 儲存預啟動程式 151 及其對應之數位簽章 152，預啟動程式 151 於本實施例為包含 Linux 內核作業系統之壓縮檔，並部署於該伺服器於 Linux 作業系統下之根目錄。預啟動程式伺服器 15 之數量為至少二個（例如三個)，且各預啟動程式伺服器 15 均持有同一令牌驗證金鑰，用以獨立驗證存取令牌。驗證伺服器 16 包含基準度量值資料庫 161 及令牌產生單元 162，基準度量值資料庫 161 儲存各機型測試機電腦之韌體與開機載入程式之合格度量值（雜湊值)。

請參閱圖 2，為本發明方法之流程圖，其步驟說明如下：

步驟 S101：測試機電腦 11 上電後，預啟動韌體 112 經區域網路 12 向 DHCP 伺服器 13 發出請求，並取得預啟動程式伺服器 15（或負載均衡處理器 14）之網路位置、驗證伺服器 16 之網路位置，以及預啟動程式 151 於預啟動程式伺服器 15 之 Linux 作業系統下之儲存路徑（例如根目錄)。

步驟 S102：預啟動韌體 112 利用驗證金鑰 113 所含之根憑證，與驗證伺服器 16 建立加密連線，並自驗證伺服器 16 取得一隨機之挑戰值。由於測試機電腦 11 已預置根憑證，縱使 DHCP 回應遭偽造而導向偽造之驗證伺服器，亦因憑證驗證失敗而無法建立連線。

步驟 S103:安全元件 111 將平台組態暫存器之值與前述挑戰值，

以其簽署金鑰進行簽署而產生證明資料（簽署引證），並經加密連線傳送至驗證伺服器 16。

步驟 S104：驗證伺服器 16 驗證證明資料之簽章，確認其所含之挑戰值為本次連線所發出（以防止重放攻擊），並將其所含之度量值與基準度量值資料庫 161 中對應該機型者比對。比對不相符時，進入步驟 S109，驗證伺服器 16 拒絕該請求並記錄告警，測試機電腦 11 不得取得預啟動程式 151。

步驟 S105：比對相符時，令牌產生單元 162 產生存取令牌，其內容包含測試機電腦 11 之識別、預啟動程式 151 之版本、有效期限（例如數分鐘）及一次性使用標記，並以令牌簽署金鑰簽署後傳回測試機電腦 11。

步驟 S106：測試機電腦 11 依步驟 S101 取得之網路位置及儲存路徑，攜帶存取令牌，以 HTTPS 向預啟動程式伺服器 15 請求預啟動程式 151 及數位簽章 152；設有負載均衡處理器 14 時，由負載均衡處理器 14 於複數預啟動程式伺服器 15 之間動態分配該請求。

步驟 S107：被分配之預啟動程式伺服器 15 以令牌驗證金鑰驗證存取令牌之簽章、有效期限及測試機電腦識別，並確認令牌尚未被使用（一次性令牌之使用狀態可由驗證伺服器 16 統一核銷）；驗證通過後，回傳預啟動程式 151 及數位簽章 152。

步驟 S108：測試機電腦 11 以驗證金鑰 113 驗證數位簽章 152；驗證通過時，載入並執行預啟動程式 151（Linux 內核作業系統）而進入診斷測試；驗證失敗時，則中止預啟動並回報驗證伺服器 16。

於其他實施例中，加密傳輸協定亦可採用 SFTP；安全元件亦可為其他具備量測與簽署功能之硬體信任根；預啟動程式伺服器 15 及負載均衡處理器 14 亦可以容器化方式（如 Kubernetes）部署，並依預啟動負載動態擴縮，惟均不脫離本發明之範圍。

【圖式簡單說明】

圖 1：本發明預啟動系統之系統架構示意圖。

圖 2：本發明具裝置身分證明之安全預啟動方法之流程圖。

【主要元件符號說明】

11：測試機電腦

111：安全元件

112：預啟動韌體

113：驗證金鑰

12：區域網路

13：動態主機設定伺服器（DHCP 伺服器）

14：負載均衡處理器

15：預啟動程式伺服器

151：預啟動程式

152：數位簽章

16：驗證伺服器

161：基準度量值資料庫

162：令牌產生單元

S101～S109：步驟

【圖式】

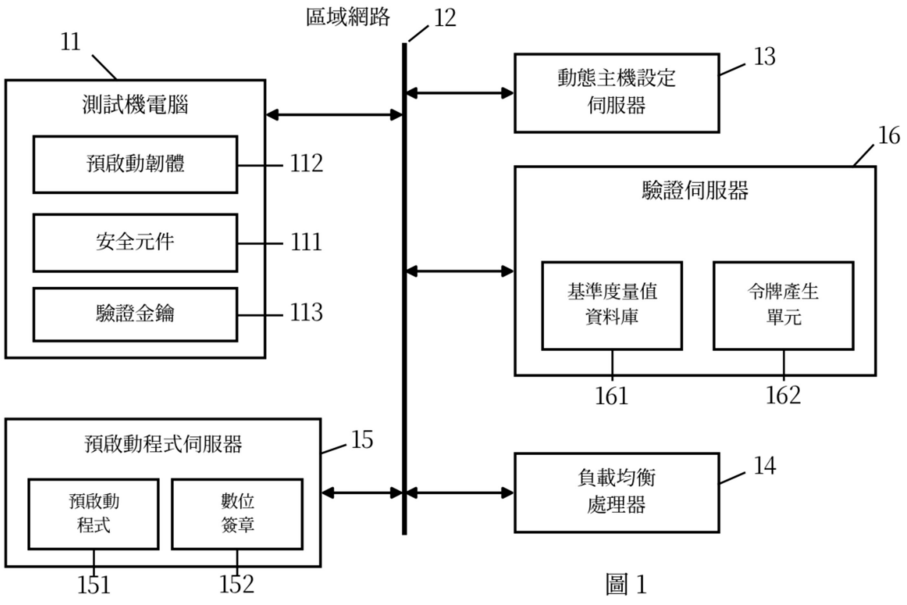


圖 1

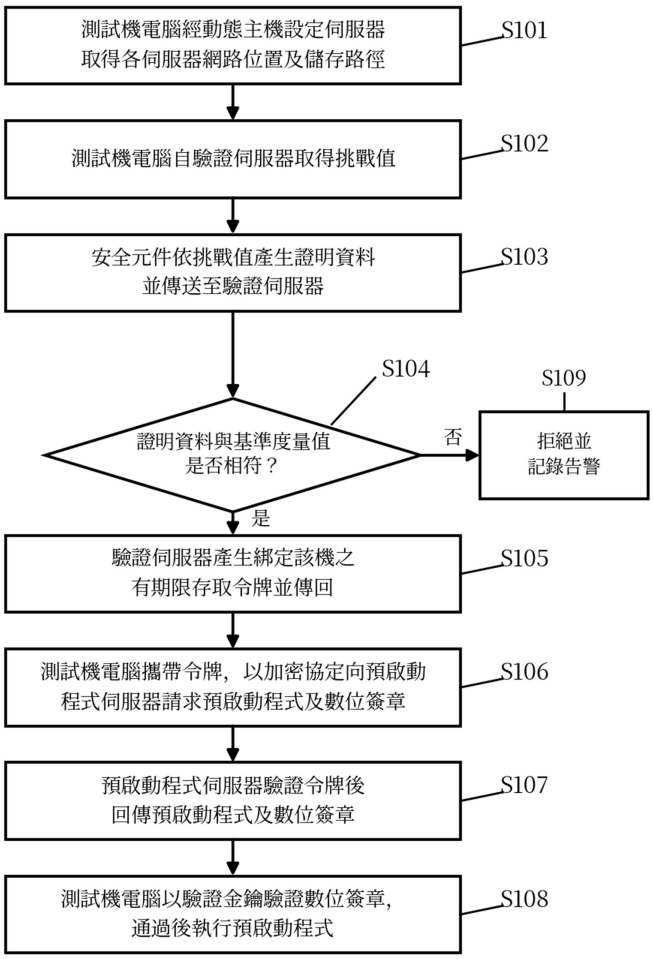

測試機電腦經動態主機設定伺服器
取得各伺服器網路位置及儲存路徑
S101
測試機電腦自驗證伺服器取得挑戰值
S102
安全元件依挑戰值產生證明資料
並傳送至驗證伺服器
S103
S104
證明資料與基準度量值
是否相符？
否
S109
拒絕並
記錄告警
是
驗證伺服器產生綁定該機之
有期限存取令牌並傳回
S105
測試機電腦攜帶令牌，以加密協定向預啟動
程式伺服器請求預啟動程式及數位簽章
S106
預啟動程式伺服器驗證令牌後
回傳預啟動程式及數位簽章
S107
測試機電腦以驗證金鑰驗證數位簽章,
通過後執行預啟動程式
S108

圖 2